COOKIE writeup

정명훈

1.문제 정의

우선 app.py에 나온 html내부의 로직과 문제의 제목 그리고 설명을 통해서 우선 이 문제의 목표는 admin으로 로그인을 해서 flag를 알아내야 하는데 문제는 파이썬 app.py에 따르면 admin의 비밀번호가 바로 flag값이라는 거다.

```
try:
    FLAG = open('./flag.txt', 'r').read()
except:
    FLAG = '[**FLAG**]'


users = {
    'guest': 'guest',
    'admin': FLAG
}
```

하지만 또다른 아이디 guest 그리고 비밀번호도 guest가 있는데 이걸로 로그인을 할 수 있다.

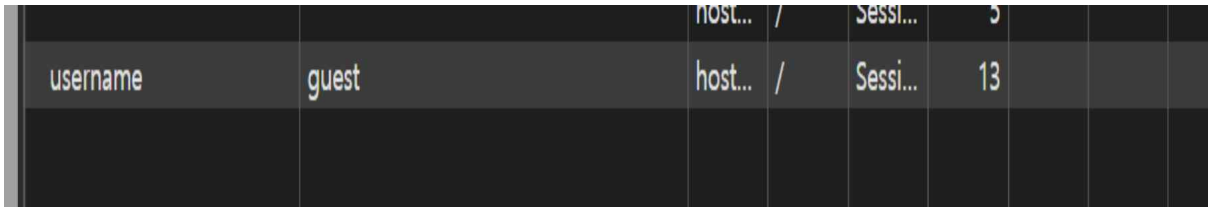
하지만 guest로 로그인을 한 경우에는 app.py의 설명처럼 flag정보는 전혀 나오지 않는데 여기서 문제에서 준 힌트 이 사이트는 쿠키로 인증 상태를 관리한다고 하고 실제로 app.py내부의 코드를 보면

username = request.cookies.get('username', None)

if username:

return render_template('index.html', text=f'Hello {username}, {"flag is " + FLAG if username == "admin" else "you are not admin"}')

와 같이 그저 쿠키값을 통해서만 admin인지를 인증하고 있다는 사실을 파악했다. 그러면 이전에 내가 배웠던 지식을 활용해 개발자 도구로 들어가 applications -> cookie에 들어가면 내 쿠키 정보를 확인할 수 있다.



그리고 app.py를 봤을 때 쿠키만 가지고 인증을 하기 때문에 username의 value를 guest에서 admin으로 바꿔주기만 하면



이렇게 admin으로 나를 인식하고 바로 플래그를 보여준다. 이걸 다시 로그인 화면으로 돌아가 id에 admin그리고 password에 flag를 입력해 보면 로그인이 잘 되는 것을 통해 이것이 정답임을 알 수 있다.

알게된 점: 이 문제를 풀면서 나는 어떠한 유저를 식별을 할 때 단순히 client에서 보낸 cookie값을 가지고 유저를 식별하는 것이 굉장히 위험한 방법이라는 것을 깨달았다. 앞으로는 절대 이렇게 코드를 짜지 않을 듯 하다.